

Chương 6 – Điều khiển truy nhập theo phân quyền tự do

Nguyên tắc của điều khiển truy nhập

- Dựa trên quy định về quyền hạn của chủ thể đối với đối tượng
- **Phân quyền** được biểu diễn bằng một

6.1) Khái niệm chung

- Điều khiển truy nhập là

với mục đích

- Chấp nhận truy nhập hợp lệ,
- Ngăn chặn truy nhập trái phép
- Một hệ thống điều khiển truy nhập gồm
 - **Chủ thể (subject):**
 - **Đối tượng (object):**

6.2) Giới thiệu Điều khiển truy nhập theo phân quyền tự do (DAC)

- DAC = Discretionary Access Control
- Đặc trưng
 - Sự phân quyền là
 - Biểu diễn phân quyền bằng

A) Ma trận truy nhập (Access Matrix)

		OBJECTS				
		A	B	C	D	E
SUBJECTS	U	r, w		r, w own		r
	V		r, w			
	W	w, own				r, w
	X	r	r	w	r, w own	

Ma trận A dạng bảng

- Mỗi hàng thể hiện một chủ thể:
- Mỗi cột thể hiện một đối tượng:
- Phần tử $A[i,j]$ của ma trận thể hiện

B) Các loại quyền truy nhập

- Quyền đọc – lấy thông tin từ đối tượng:
- Quyền ghi – sửa đổi thông tin của đối tượng:
- Quyền xóa – hủy bỏ đối tượng:
- **Quyền sở hữu** - làm chủ hoàn toàn đối tượng :
- Quyền thực thi – triệu gọi một đối tượng (chương trình) :

C) Cài đặt ma trận truy nhập

- Ma trận truy nhập là mô hình biểu diễn phân quyền DAC.
- Khi áp dụng vào hệ thống, cần cài đặt ma trận truy nhập thành các dạng cấu trúc dữ liệu cụ thể

i) Phương pháp bộ ba S-O-P

- Dựa trên bộ ba phân quyền gồm có: chủ thể S, đối tượng O và quyền truy nhập P
- Dữ liệu của ma trận được lưu trong một bảng T
- Mỗi hàng của bảng T

Bộ ba truy nhập dạng bảng

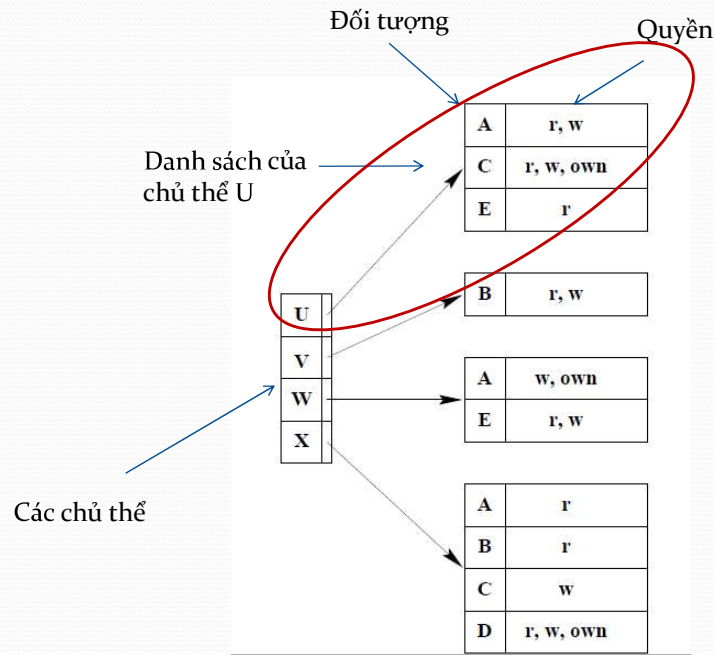
Subjects	Objects	A[s,o]
U	A	r, w
U	C	r, w, own
U	E	r
V	B	r, w
W	A	w, own
W	E	r, w
X	A	r
X	B	r
X	C	w
X	D	r, w, own

Đặc điểm của phương pháp

- Thích hợp và thường được triển khai trong
 - Hệ thống thông tin
- Case Study: Phân quyền trong

ii) PP khả năng truy nhập (Capabilities)

- Cài đặt ma trận truy nhập theo từng
- Mỗi một chủ thể S_i được tạo một danh sách gồm



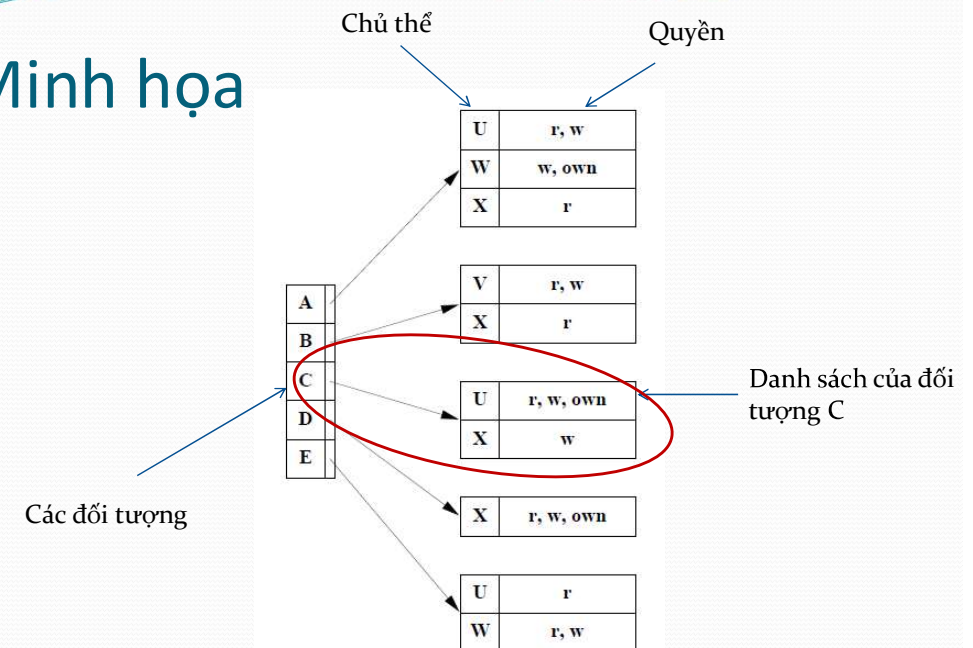
Đặc điểm của phương pháp

- Dễ quản lý và điều khiển truy nhập
- Tuy nhiên, không thuận lợi trong điều khiển truy nhập
- Thường ứng dụng trong
- Case Study: Phân quyền hệ thống truy nhập file từ xa

iii) PP danh sách điều khiển truy nhập (Access Control List)

- Cài đặt ma trận truy nhập
- Mỗi đối tượng O_i được gắn với một danh sách các cặp

Minh họa



Ưu nhược điểm

- Dễ quản lý và điều khiển truy nhập
- Không thuận lợi theo điều khiển
- Ứng dụng trong những
với số lượng đối tượng nhiều và hay thay
đổi, số lượng chủ thể ít và tương đối ổn định
- Case study: Phân quyền truy nhập

6.3) Chuyển giao quyền truy nhập (Propagation of Access)

- Chuyển giao quyền là sự mở rộng của mô hình DAC,

A) Chuyển giao tự do

- Nếu chủ thể U có quyền truy nhập đối với đối tượng O
• U có thể cấp mọi quyền truy nhập O cho chủ thể V bất kỳ
• U có thể cấp quyền truy nhập O cho V
- Ma trận truy nhập thay đổi

Minh họa

Chuyển giao tự do không có giới hạn

OBJECTS

		A	B	C	D	E
SUBJECTS	U	r, w		r, w own		r
	V		r, w			
	W	w, own				r, w
	X	r	r	w	r, w own	



B) Chuyển giao có giới hạn

- truy nhập để cấp quyền
 - Quyền sao chép: **read-copy**
 - Quyền cấp phép: **grant**

- Chủ thể có quyền read-copy (rc) thì

- Chủ thể có quyền **grant** (g) thì có thể

Minh họa quyền read - copy

		OBJECTS				
		A	B	C	D	E
SUBJECTS	U	r, w		rc, r own		r
	V		r, w			
	W	w, own				r, w
	X	r	r	w	r, w own	

Minh họa quyền grant



		OBJECTS				
		A	B	C	D	E
SUBJECTS	U	r, w		rc, r own	g	r
	V		r, w			
	W	w, own				r, w
	X	r	r	w	r, w own	

6.4) Mô hình HRU

- HRU là một mô hình điều khiển truy nhập do Harrison, Ruzzo và Ullman đề xuất vào năm 1976
- HRU thuộc dạng
 - Sử dụng
 - Hỗ trợ chuyển giao, thay đổi quyền

A) Cấu trúc của mô hình HRU

- Gồm
- Tập và tập
- Một tập hữu hạn

B) Lệnh (chương trình) HRU

Một lệnh (còn gọi là chương trình) HRU có dạng

```
command <tên lệnh> ( $X_1, X_2, \dots, X_n$ ) { $X$  là tham số đại diện cho chủ thể hoặc đối tượng  
if <điều kiện>  
then  
    {thực hiện một chuỗi các thao tác trên ma trận  $A$ }  
fi  
end
```

Khi được gọi ra thực hiện,

Điều kiện trong lệnh HRU

- Điều kiện là biểu thức logic để
- Ví dụ:
 - $r \text{ in } A(S,O) = \text{true} \Leftrightarrow$
 - **if** $r \text{ in } A(S_1,O_1)$ **AND** $w \text{ in } A(S_2,O_2)$ **then** $\Leftrightarrow$

6 thao tác cơ bản trong lệnh HRU

- Thêm quyền:
- Xóa quyền:
- Tạo chủ thể mới : **create subject S**
- Tạo đối tượng mới: **create object O**
- Xóa chủ thể: **delete subject S**
- Xóa đối tượng: **delete object O**

C) Một số quy tắc của mô hình HRU

- Lệnh HRU chỉ được thực thi nếu
- Biểu thức điều kiện
trong ma trận A
- Ma trận truy nhập ban đầu

Ví dụ lệnh HRU

Lệnh HRU cho phép chủ thể U cấp quyền đọc đối với đối tượng O cho chủ thể V

Điều kiện: Chủ thể U **có quyền sở hữu hoặc quyền rc** đối với đối tượng O

```
command copy_read (U,V, O)
if
then

fi
end
```

Tiếp

Hãy viết lệnh HRU để chuyển giao quyền sở hữu đối với đối tượng O từ chủ thể U sang chủ thể V

```
command transfer_own (U,V, O)
if
then

fi
end
```


- Tập lệnh HRU thể hiện

trong ma trận

- Khi triển khai HRU, cần phải
 - Xác định
 - Dựa trên từng trường hợp để

6.5) Hạn chế của mô hình DAC

- Phân quyền tự do làm cho quản lý sự thay đổi của phân quyền khó khăn
 - Khó dự đoán trước được
 - Khó đảm bảo được
- **KHÔNG** phòng chống được

Trojan Horse là gì?



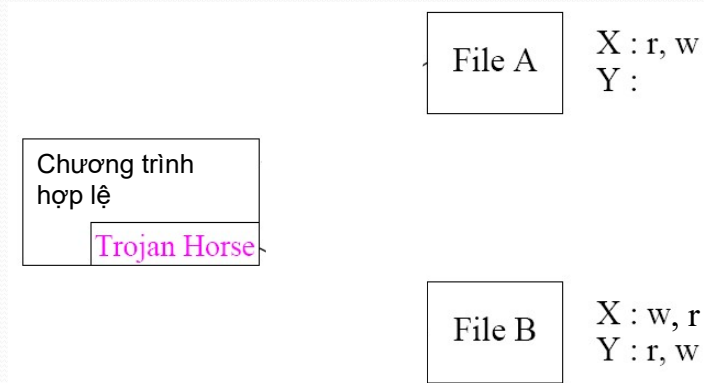
- Trojan horse là một đoạn mã chương trình được gài vào bên trong một chương trình hợp lệ.
- Khi người dùng chạy chương trình hợp lệ thì trojan horse cũng được kích hoạt và tiến hành các hành động mà người dùng không biết và không ngờ đến
 - Truy nhập trái phép, đánh cắp thông tin
 - Thực hiện các hành vi phá hoại dưới danh nghĩa chương trình hợp lệ

Ví dụ: trojan horse tấn công mô hình DAC

File A	X : r, w Y :	X có quyền đọc và ghi A Y không có quyền truy nhập A
File B	X : w Y : r, w	X có quyền ghi B Y có quyền đọc và ghi B

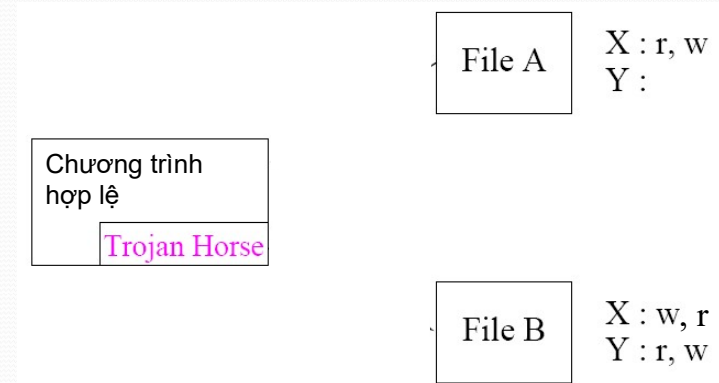
Làm thế nào, Y có thể truy nhập và đọc dữ liệu từ A?

Trojan horse vượt qua điều khiển của DAC



Y tìm cách lừa X cài Trojan horse. Khi được X kích hoạt, trojan horse đọc thông tin từ file A và ghi vào file B.

Trojan horse vượt qua điều khiển của DAC



Y sửa thông tin của A trên file B. Trojan horse đọc thông tin đã sửa từ file B và ghi vào file A.